M T W T F S S
Page No.:
Date:
YOUVA PELLAR

4. Next-Generation Firewall (NGFW) - Combines advance traffic inspection with application awereness & other security features.

12.10.26

Case Study:
Securing the University Examination System

→ A university uses an Operating System-based examination management system to store student records, marks, faculty details & question papers. The system has three main user groups: Students, Faculty & Admin. Students should be able to view only their own marks & download permitted learning materials. Faculty members need to view student records & enter or modify marks. Administrators manage user accounts, permissions & system configuration.

→ The university has assigned permissions through roles, but an audit review identifies the following events:

- At 10:00, the account Student07 has 3 failed login attempts.
- At 10:03, Student07 successfully logs in.
- At 10:04 Student07 attempts to open ExamMarks.xlsx, by which contains the marks of the entire class.
- At 10:05 the system records an attempted modification of ExamMarks.xlsx by Student07

- At 10:15, Faculty 02 modifies marks in the file & saves the file successfully.
- At 10:20, an administrator discovers that a former faculty member's account is still active.
- The audit log is stored on the same server, & users with broad permissions may be able to modify or delete it.

→ The university wants to protect confidentiality, integrity & availability; prevent unauthorized access; maintain accountability; & investigate suspicious activity. You are asked to recommend appropriate OS access-control, security-administration & auditing measures

Questions

Q1 Identify the main security problems in the case study. (4 marks)
→ list at least four risks or weaknesses indicated by the senario.

Q2 Explain the difference between authentication & authorization using Student07 as an example. (4 marks)
→ Distinguish identity verification from permission checking.

Q3 Recommend an access-control policy for Students, Faculty & Administrators. Justify your choice. (5 marks)
→ Consider how permissions should be assigned & managed.

Q4 Prepare a suitable Access Control List (ACL) for ExamMarks.xlsx. (5 marks)

→ Specify appropriate, Read, Write & Delete permissions for each user group.

Q5 Explain how the Principle of least Privilege should be applied in the System. (4 marks)

→ State what each group needs to do & which unnecessary permissions should be removed.

Q6 Interpret the audit events from 10:00 to 10:05. What should the security team do next? (5 marks)

→ Explain why the sequence is suspicious without assuming that it proves an attack

Q7 Identify at least 5 events that should be recorded in the audit logs. (3 marks)

→ Include login, file, account, permission and/or administrative events.

Q8 Explain why the audit logs must be protected & tell 2 ways to protect them. (3 marks)

→ Consider unauthorized modification, deletion & investigation.

Q9 What action should be taken regarding the former faculty member's active account? Explain. (3 marks).

→ Account management & access removal

Q10 Suggest a practical incident-response & corrective-action plan for the university. (4 marks)

M T W T F S S

Page No.:

Date:

YOUVA STELLAR

Answers

Q1) Main security problems:

→ Users are allowed unlimited login attempts.

→ Old users still have access to their accounts & sensitive information

→ Audit logs can be modified & deleted.

→ Weak & similar passwords make it easier for unauthorized users to gain access to sensitive information.

Q2)

Authentication	Authorization
- Student07 logged in successfully on the 4th attempt. - Authentication means checking the identity of the User which in this case occured by entering the correct password.	Student07 was allowed access to view the ExamMarks.xlsx document but not edit it. Authorization means what the user is allowed to do. In this case the student could read the file but not edit it.

Q3) The University should use Role Based Access Control (RBAC) Policy in which permissions are assigned to roles rather than individual users. Users can have one or more roles.

→ Students will be allowed only to view their marks & download permitted learning materials.

→ Faculty will be allowed to view student records & modify & enter marks

→ Administrators manage user accounts

permissions & configure the system.

4) Access Control List (ACL) for ExamMarks.xlsx

User group	Read	Write	Delete
- Student	Yes (Only own marks)	No	No
- Faculty	Yes	Yes	No
- Adminstrators	Yes	Yes	Only with approval

5) - Students need only read privilage to their own data. Any other writing, deleting & reading access should be removed.

- Faculty need reading access to read student records and writing access for marks and learning material entry. Any other deleting or admin access should be ~~deleted~~ removed.

- Administrators need access to manage accounts & systems. Any ability to change logs & marks should be removed.

6) Student07 first fails to login three times before successfully logging in the fourth time. Then they try open the Exammarks.xlsx file & attempt to

modify the file. This is suspicious because it looks like an attempt at password guessing followed by modification of a file students should not have full access to.

The security team should check if the file was modified and monitor or review the account logs. They should also contact the student to confirm if it was them.

7) Events to be logged
→ Failed and successful login attempts
→ Attempts to modify or delete files and access to them.
→ Creation, disabling or deletion of accounts
→ Changes in role or account permissions
→ Administrative abilities / permissions

8) → Logs are evidence for accountability & investigation. If someone can modify or delete them, they can hide their crimes & then the logs cannot be trusted
→ Ways to protect the logs:
- Restrict log access to only authorized users like administrators & security.
- Storing them with read & write only access
- Backing up the logs & using digital signatures to detect tampering.

M T W T F S S
Page No.:
Date:
YOUVA CELLAR

9) Former faculty member accounts should be disabled.
- Access to the account should be removed.
- The permissions & information on the account should be deleted as well.
- These accounts are an easy way in for attackers & it can lead to further security issues.

10) Investigation: Checking & preserving the logs for evidence. Faculty02's changes should be checked & restored if neccassary. Student07's logs should be checked & the student should be contacted to confirm it was them.

Access review: Checking all account permissions and removing unessary access. Removing & disabling former accounts & applying least privilage.

Policy changes: Add account MFA & require approval for ~~bulk~~ mark changes. Make sure logs cannot be modified & that they are backed-up. Making account removal part of the user's exit process.

Follow-up monitoring: Setting alerts for failed logins and file modification attempts. Regular access reviews & staff awareness & training.